



Government
Digital & Data

Threat Modelling

CDDO Secure By Design

Agenda

- Welcome and housekeeping
- Background to Secure by Design
- Threat modelling in theory and practice
- Q&A

The background features a solid light green field. In the top-left corner, there is a pink shape with a stepped, L-like profile. On the right side, there are two yellow shapes: a vertical bar and a larger, more complex shape with rounded corners and a stepped edge. The text is positioned on the left side of the green field.

Background to Secure by Design

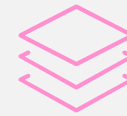
About Secure by Design



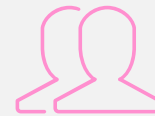
Learn about Secure by Design at
security.gov.uk



Improves cyber resilience
across government organisations



Incorporates **cyber security**
practices throughout the digital
delivery lifecycle



Highlights cyber security risks as
business risks and makes
security everyone's
responsibility

Key elements

What government delivery teams and security professionals need to do to incorporate effective cyber security practices when building digital services and technical infrastructure.

Increasing cyber resilience across government organisations

This approach promotes a positive security culture and encourages project teams to make cyber security everyone's collective responsibility.



[About Secure by Design](#)

The purpose of this framework and how it has been developed.



[Secure by Design Policy](#)

The scope of this approach and the elements that service delivery teams must meet.



[Secure by Design Principles](#)

Foundations required for embedding cyber security practices in digital delivery.



[Secure by Design Activities](#)

Recommended practical guidance to help delivery teams meet the principles.



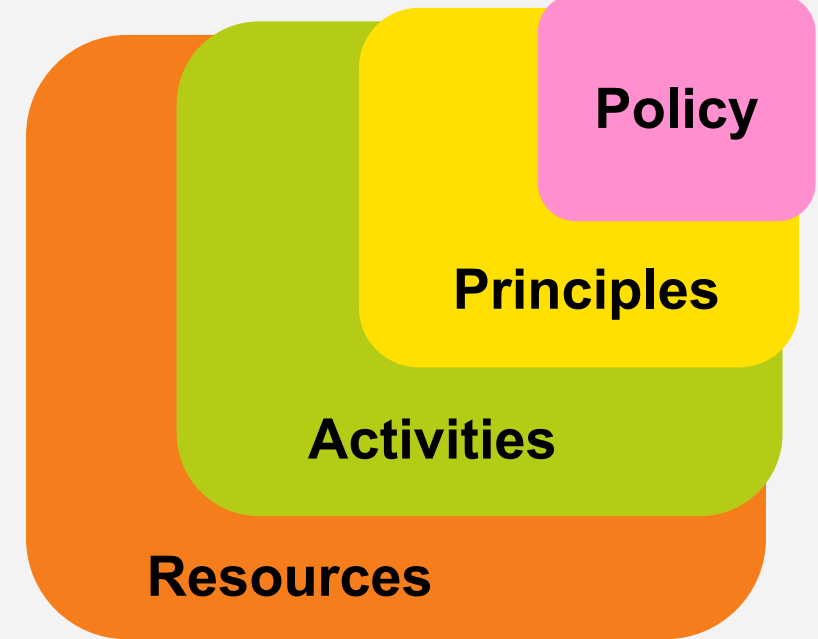
[Implementing Secure by Design](#)

Details of the rollout plan for affected organisations.



Mandatory

Monitored via the CDDO digital and technology spend control process and, once new systems services are live, GovAssure.



Recommended

To to be adapted by organisations to reflect their internal structure, processes, governance, culture and resources.

The principles

[Read more on security.gov.uk](https://security.gov.uk)



- 1** Create responsibility for cyber security risk
- 2** Source secure technology products
- 3** Adopt a risk-driven approach
- 4** Design usable security controls
- 5** Build in detect and respond security
- 6** Design flexible architectures
- 7** Minimise the attack surface
- 8** Defend in depth
- 9** Embed continuous assurance
- 10** Make changes securely

The activities

[Read more on security.gov.uk](https://www.security.gov.uk)



Prepare a secure service

Identifying security resources

Working out the project's security risk appetite

Tracking Secure by Design progress

Agreeing roles and responsibilities

Considering security within the business case

Managing third-party product security risks

Understanding business objectives and user needs

Understand the security landscape

Understanding cyber security obligations

Manage your security risks

Responding to and mitigating security risks

Assessing the effectiveness of security controls

Agreeing a security controls set for your service

Sourcing a threat assessment

Documenting service assets

Performing a security risk assessment

Assessing the importance of service assets

Performing threat modelling

Anticipate and respond to vulnerabilities

Implementing a vulnerability management process

Managing observability

Discovering vulnerabilities

Maintain continuous assurance

Evaluating the security impact of changes

Retiring service components securely



Includes resource

The benefits of threat modelling

- Early and proactive identification of potential security risks
- Informed cyber security risk management decisions
- Improves collaboration across teams
- Enhanced system resilience

**Government
Security**

About UsSearchContactSign in

Policy, Standards & Guidance ▾Services & Resources ▾Government Security Profession ▾News & Events ▾

BetaWhat do you think of this service? Your [feedback](#) (Opens in a new tab) will help us to improve it.

[Home](#) > [Policy, Standards & Guidance](#) > [Secure by Design](#) > [Secure by Design Activities](#) > Performing threat modelling

Author: Central Digital and Data Office (CDDO), Cabinet Office

Table of Contents

- [Who is involved](#)
- [How to perform threat modelling](#)

Performing threat modelling

When delivering a service you need to understand how robust it will be when faced with cyber attack techniques which could be used to exploit vulnerabilities.

Threat modelling is a highly technical security activity and should be conducted by cyber security specialists with input from your delivery team. Engage with your organisation's risk management team to determine what support they can provide for your service.

Threat modelling is the follow-up activity to a [threat assessment](#). Once you have gathered information on the motivation, intent and capability of threat actors, you should explore possible vulnerabilities and issues that might apply to your service. This will allow you to:

- identify likely threat events and how they may be conducted by attackers
- discover how non-malicious system failures may affect the availability or security of your service
- articulate pertinent security risks and justify the need for appropriate and proportionate security measures
- proactively build security controls into the service that reflect defined threats on the service's attack surface
- consider the threats that other compromised services pose to your service and the threat your service would pose to other services if it were compromised

Threat modelling should take place during the service design and build phase as a precursor to carrying out a [risk assessment](#). It should be repeated during the delivery lifecycle whenever there are design changes that have security implications, or when new threats that can potentially compromise your service are identified.

Completing this activity will help you to achieve the outcomes included in the [Secure by Design principles](#) to adopt a risk-driven approach and minimise the attack surface.

Who is involved

This is an activity performed by cyber security specialists either within your delivery team, from your organisation, or through an external consultancy.

The work of treat modelling experts should be facilitated by your Senior Responsible Officer (SRO), service owner and programme manager with input from technical and security professionals within your project.

How to perform threat modelling

The following steps are a description of the process that cyber security professionals will go through when performing threat modelling. This will change depending on the nature of your service and the setup of your organisation.



**An introduction
by today's
speaker**

Who am I and what do I do?

- Matt O'Grady, Security Architect within the **Cabinet Office Cyber and Information Security** team
- Member of the **Security Architecture & Advisory team**, working across the department to deliver a number of security architecture capabilities, including **threat modelling**
- Developed the department's threat modelling methodology, maturing a previously ad hoc process into a consistent and repeatable service
- Some teams that I've helped with threat modelling include: Cabinet Office Intranet; Cabinet Office Login Application; GDS Emergency Alerts; and, more recently CDDO SbD Artefact Library.



Cabinet Office Digital

Session Structure

- Threat modelling fundamentals
- Threat modelling operating models
- A practical example of hybrid threat modelling
- Hybrid threat modelling at the department scale



Threat modelling fundamentals

A definition of threat modelling

In a single sentence, threat modelling is:

“

*a term applied to the **techniques** (...) used to model and analyse technology systems and services to better understand **how that system or service might be attacked** or otherwise fail, and the **measures or controls needed to manage the risk** posed by such attacks or failings.*



But what does that really mean?

This definition and many others created by those across the industry (e.g., NIST) often describe threat modelling **only up to its objective**, as opposed to providing a prescriptive technique to successfully threat model a system or service.

Threat modelling **cannot be defined by a single technique**, but a set of techniques that when brought together **form a methodology** that should be aligned to development practices and delivery models of a team, business unit or organisation as a whole.

So, how do we know what “good” looks like when building a threat modelling methodology?

Enter, the...



THREAT MODELING MANIFESTO

The Threat Modelling Manifesto

Created by threat modelling professionals, academics, authors, and hands-on experts as a guide to help other security professionals **develop or refine** a threat modelling methodology.

The manifesto defines **guidelines** in the form of:

- a core **set of values** collectively agreed to have relative merit or importance when threat modelling;
- a set of **principles** that enable successful threat modelling, including **patterns** that are recommended and **anti-patterns** to be avoided when implementing a methodology.



Manifesto patterns & anti-patterns

Patterns

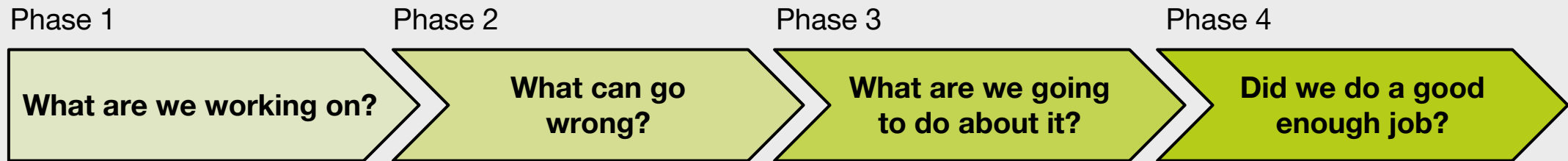
- ✓ The techniques adopted have been **field-tested** and are **informed by current industry recommendations**
- ✓ The process is **supported by tools** that enhance productivity, foster creativity and enable measurability
- ✓ A **diverse team with varied viewpoints** contributes throughout the entire process
- ✓ The approach is **systematic**, and structured in a way that is repeatable

Anti-patterns

- ✗ The process **relies on an individual “hero”** threat modeller and their unique skills or mindset
- ✗ Time is spent **admiring the problem**, rather than addressing it
- ✗ Too much **emphasis and focus is placed on small details**, and sight is lost of the big picture
- ✗ Meaningful progress is suppressed due to the **pursuit of the “perfect” representation**

Shostack's Four Question Framework

The most popular and widely used **systematic approach** to threat modelling is Adam Shostack's Four Question Framework.



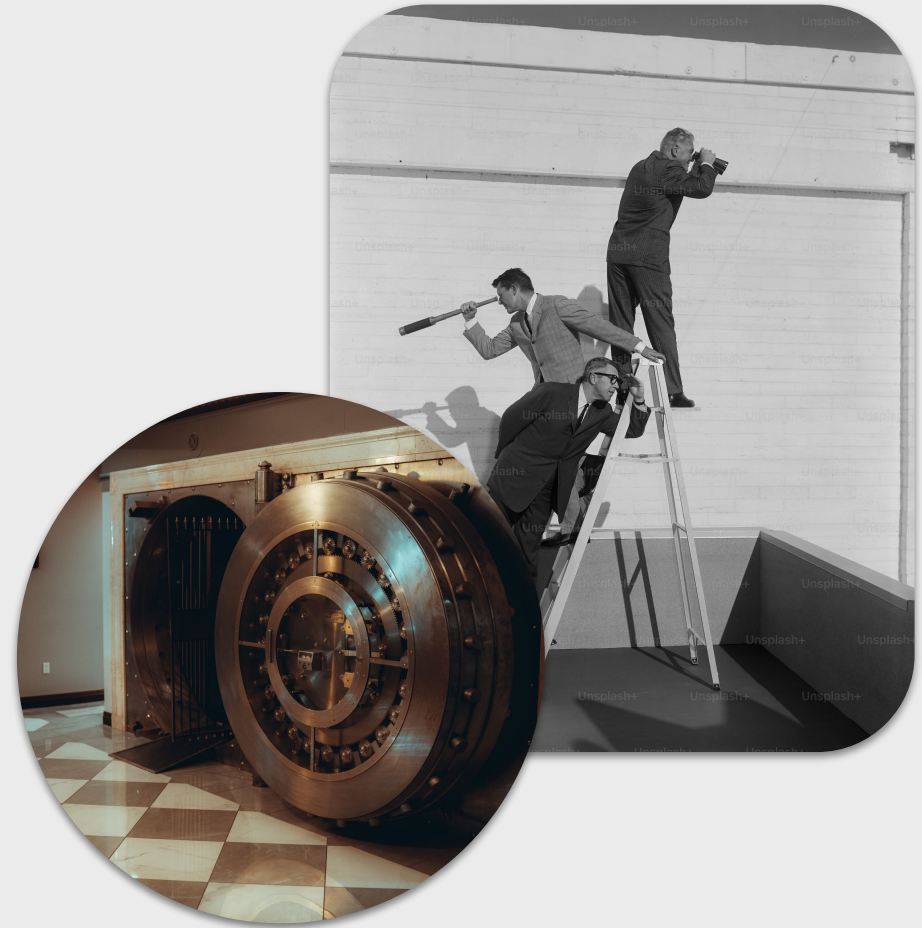
This framework is **not a methodology** in itself, but a structure around which a threat modelling methodology can be developed that fits our needs. The **objectives** of each phases are met through use of a **set of tools and techniques**, when combined form the methodology.

But ultimately, if you are answering these questions, you are threat modelling!

Phase 1 – What are we working on?

Objectives

- **Define threat modelling context**, including:
 - motivation, scope, assumptions
 - the stakeholders involved in creating and reviewing the threat model
- **Gain a shared understanding of service**, including:
 - service goals and primary objectives
 - entry points, components and data flows between them
 - users and assets, including the “crown jewels”
 - the most likely threat actors / threat sources, and their motivations, skills and goals



Phase 1 – What are we working on?



Techniques to consider

- Asynchronous review of design documents, user stories, architecture and data flow diagrams
- Collaborative working groups to discuss gaps in documentation and shared understanding
- Group diagramming sessions
- Threat intelligence and assessments

Tools to consider

- For documentation – Confluence, SharePoint, Google Workspace or Office 365 software suite
- For diagrams – Draw.io, Lucid, Figma, or even a physical whiteboard!

Phase 2 – What can go wrong?

Objectives

- **Decompose** threat model scope into components (e.g. elements, interactions, and/or features)
- **Brainstorm** collaboratively to identify threats to assets and objectives of the service components
- **Document** threats in a structured and consistent manner, taking into account:
 - threat source;
 - threat actions and their prerequisites;
 - the result and impact of the threat to service assets and/or objectives;



Phase 2 – What can go wrong?



Techniques to consider

- Collaborative workshops, structured around threat categories and frameworks, including: STRIDE; MITRE ATT&CK; or Cyber KillChain.
- Create or use a prescribed structure for threat statements, e.g. AWS Threat Grammar
- Attack trees (advanced, out of scope)

Tools to consider

- For brainstorming sessions – digital whiteboard solutions, e.g., Mural, Miro, FigJam, Jira Diagramming, Lucidspark
- For attack trees – attacktree.online or [Draw.io](https://draw.io)

Phase 3 – What are we going to do about it?

Objectives

- **Prioritise threat mitigations**, in an order influenced by factors affecting the impact and likelihood of a threat occurring
- **Document threat mitigations** starting from highest to lowest priority, where mitigations can include people, process and/or technology-related actions
- **Present outcomes** in a form that is relevant and appropriate for threat modelling stakeholders, both technical and non-technical.



Phase 3 – What are we going to do about it?



Techniques to consider

- Collaborative workshops to prioritise threats and brainstorm mitigations – often prioritising some threats beforehand is beneficial
- If you need inspiration, MITRE ATT&CK and CWE mitigation libraries are useful, along with departmental or gov-wide guidance docs

Tools to consider

- For threat prioritisation and mitigation sessions – digital whiteboard solutions, e.g., Mural, Miro, FigJam, Jira Diagramming
- For presenting outcomes – enterprise productivity platforms (e.g., Google Workspace or Office 365).

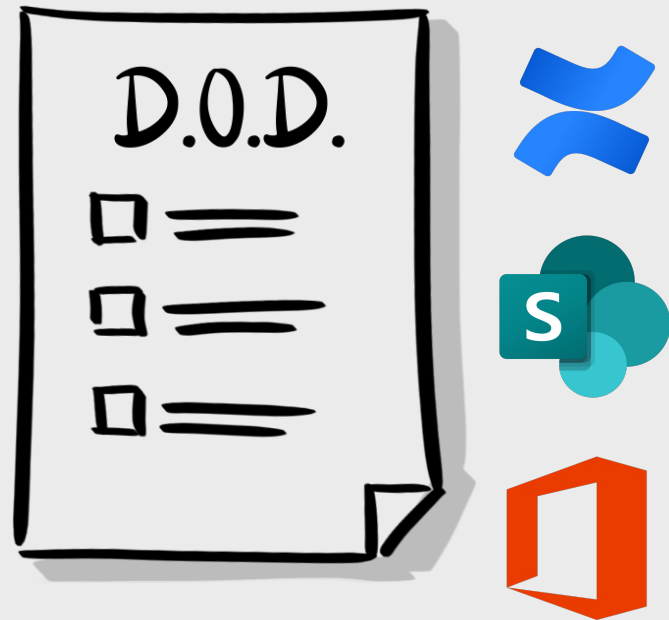
Phase 4 – Did we do a good enough job?

Objectives

- **Assess** the threat modelling outputs against the four question framework:
 - Phase 1 – was the level of detail present in the diagram satisfactory?
 - Phase 2 – did the quantity and quality of threat statements align with expectations?
 - Phase 3 – was agreement reached with stakeholders on the priority of threats and quality of proposed mitigations?
- **Evaluate** the process as a whole – did the tools and techniques enhance productivity, foster creativity and enable measurability?



Phase 4 – Did we do a good enough job?



Google Workspace

Techniques to consider

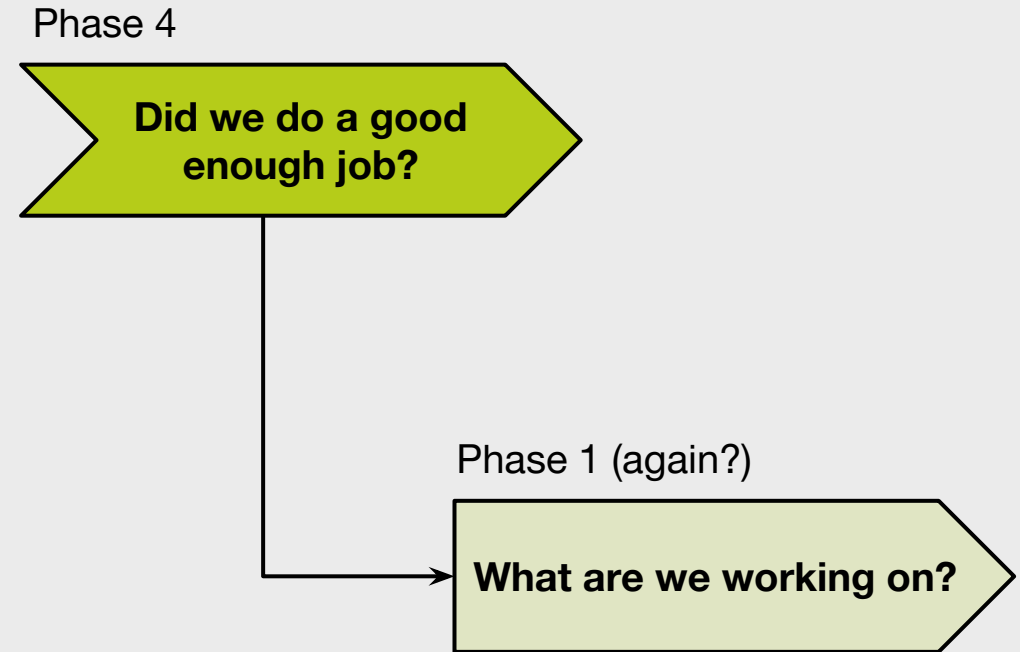
- Generate a set of questions that can be used to assess the quality of the threat model
- Create a “definition of done” incorporating these questions, which can be used to determine if the current threat model exercise is complete
- Run collaborative workshop to assess the threat model, and agree that the definition of done has been met – this should include relevant stakeholders

Tools to consider

- For documenting and sharing discussion outcomes – Confluence, SharePoint, Google Workspace or Office 365 software suite

How often should threat modelling take place?

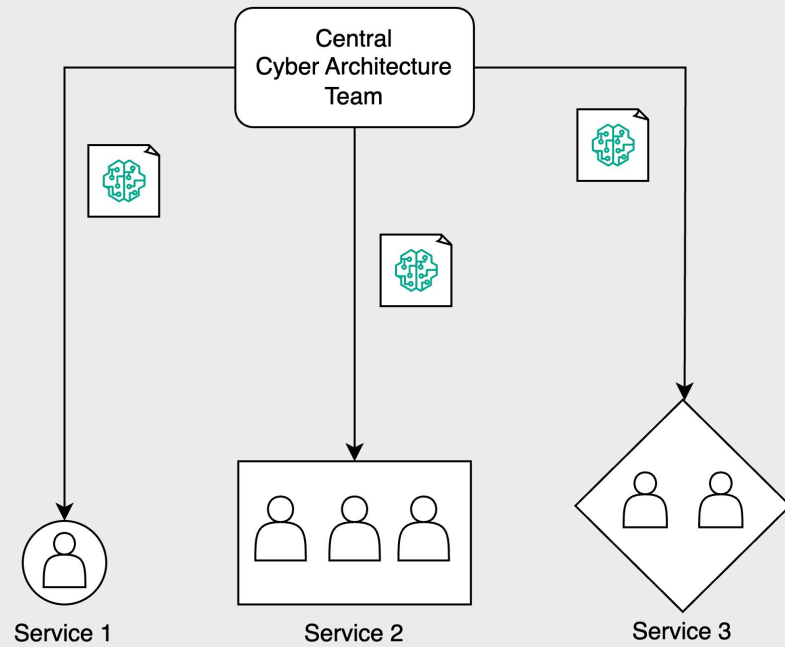
- Threat modelling should first take place **during the design phase**, once a draft service architecture has been established
- There are **no strict frequency** thereafter, however it should be revisited at least after (1) each phase of the delivery lifecycle; (2) the proposal of major architectural changes; and (3) any changes to the threat landscape of the service.
- Threat modelling is a **continuous process**, and is only really “done” following the service decommissioning.



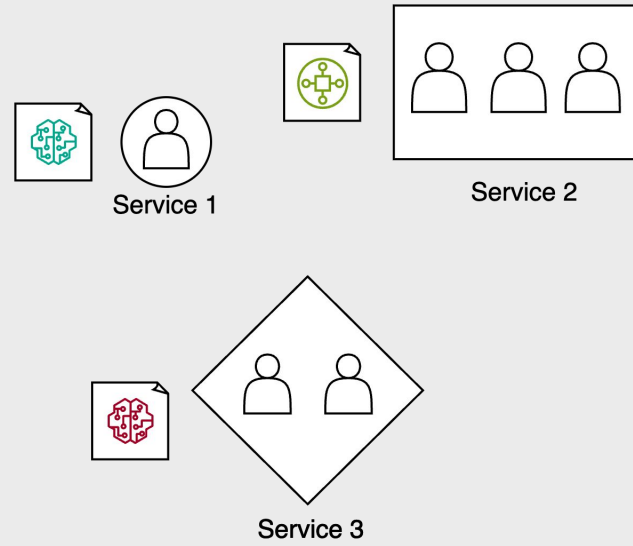


Threat modelling operating models

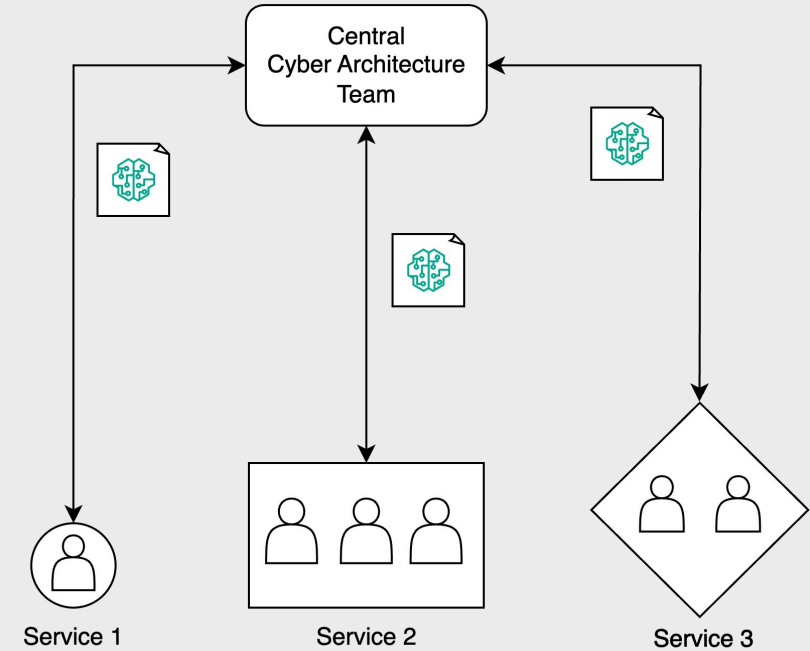
Threat modelling operating models



Centralised



Decentralised



Hybrid

What does our hybrid operating model look like?

Phase 1

What are we working on?

- Service team **draft a data flow diagram**, comprising at least – one asset, one entry point, and two components;
- Collaborative review of threat assessments relevant to the service, to understand threat profile and likely threat sources
- Collaborative discussion with stakeholders to agree and document threat modelling motivations, scope and **shared responsibilities** for delivery

Phase 2

What can go wrong?

- **Cyber Architecture** facilitate (at least) one collaborative workshop to identify threats to the service components in scope, usually 1 to 1 ½ hours in length
- Workshops were historically held using Jamboard, but more recently using Draw.io whiteboard
- **STRIDE-per-element** is used to identify threats, with statements aligned to **AWS Threat Grammar**. Attack trees are used where an in-depth technical threat model is required for stakeholders

What does our hybrid operating model look like?

Phase 3

What are we going to do about it?

- Cyber Architecture team **facilitates another collaborative workshop** via Draw.io whiteboard to determine threat priority and identify mitigations
- Cyber Architecture team **creates a spreadsheet** to document threats statements and proposed mitigations
- If agreed in our shared responsibility model, Cyber Architecture team also **drafts an executive summary** to present to senior stakeholders

Phase 4

Did we do a good enough job?

- Threat modelling outputs peer reviewed within Cyber Architecture team to **ensure our definition of done is met**
- Service team **shares outputs with stakeholders** including SRO and/or service owner
- Service team **agree threat model review frequency** with Cyber Architecture in line with service delivery lifecycle
- Cyber Architecture **advise during the implementation** of proposed mitigations, prior to next threat modelling exercise



An example of hybrid threat modelling*

Service and threat modelling context

Scenario

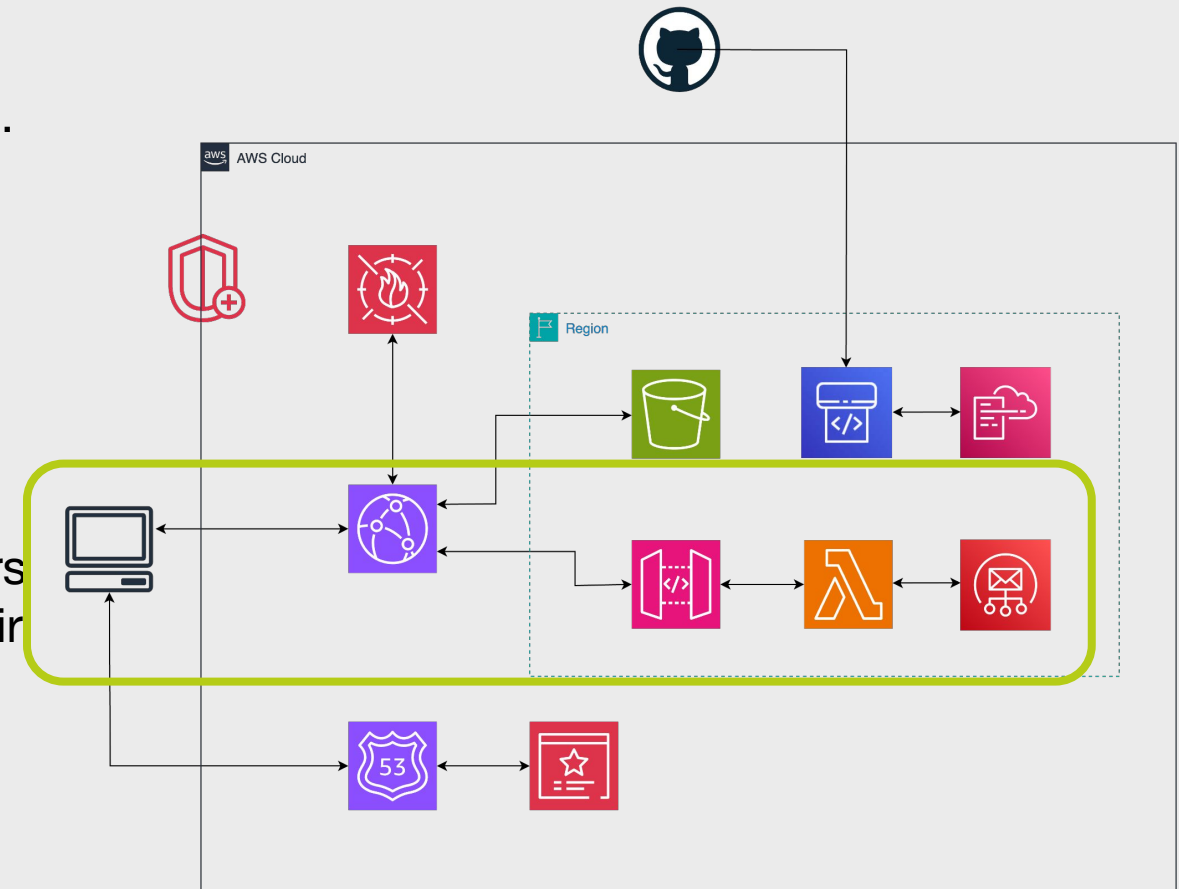
- We (the central security team) have been approached to threat model an **example** service.

Service Objective & Goals

- Cabinet Office policy landing page, a serverless web application (hosted on S3) to view department policies, standards and guidance.

Motivation & Scope

- A new feature is in development that allows users to share feedback on policy documents with their authors.
- Only the new features, i.e. new form / front-end content, the API, Lambda and SES are in scope (circled in green).



Service and threat modelling context

The service team has defined the entities in scope, and the central cyber team has provided threat intelligence to define likely threat sources.

External entities

- **End users** – Cabinet Office staff, but web pages will be publicly accessible from across the internet
- **Delivery and Ops team** – developers and a platform engineering team, responsible for maintaining the app and modify content on behalf of policy authors

Threat sources

- According to central threat assessment and supporting threat intelligence reporting, the likely threat actors are: Hostile State Actors, Insiders and Hacktivists.

 Cabinet Office Digital

STRATEGIC CYBER THREAT INTELLIGENCE REPORT

What is the cyber threat landscape for the Cabinet Office?

 Cabinet Office

TECHNICAL THREAT INTELLIGENCE REPORT

What threat does ransomware pose to the Cabinet Office?

 Cabinet Office Digital

CYBER THREAT INTELLIGENCE REPORT

Pro-Russia hacktivist group “Killnet” conducting DDOS attacks

Data Flow Diagram (DFD)

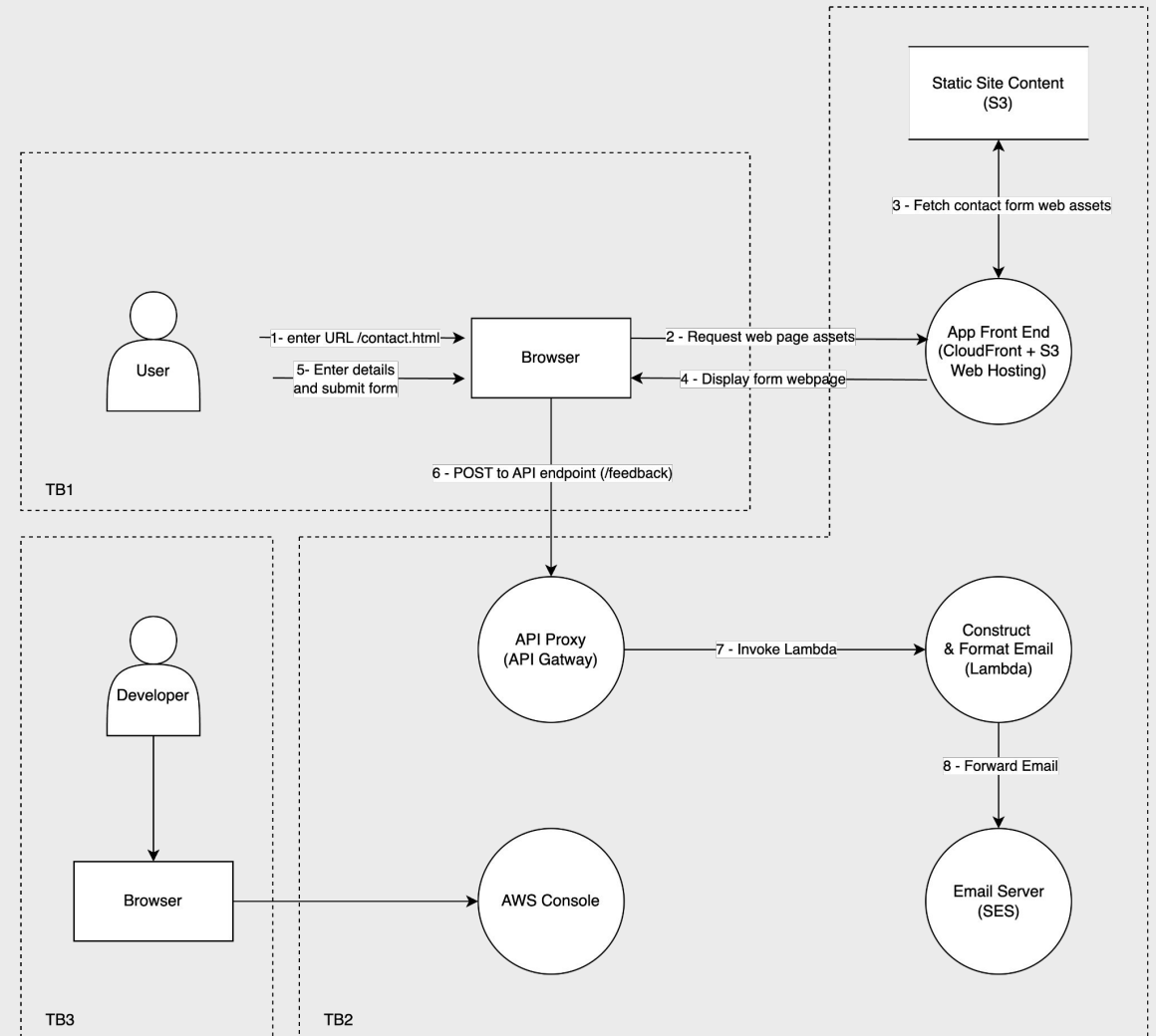
The service team has defined a data flow diagram and assets of interest.

Assets in scope

- Static site content (HTML, JS, CSS) representing the feedback form
- User data submitted via the form (e.g., name, email, URL of policy document, comments / feedback)

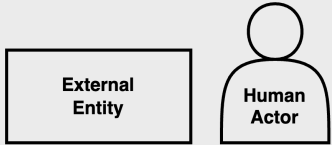
Shared responsibility agreement

- We (central cyber architecture team) have agreed to facilitate the threat modelling workshop on the given scope, and will lead on the creation of the mitigation spreadsheet.



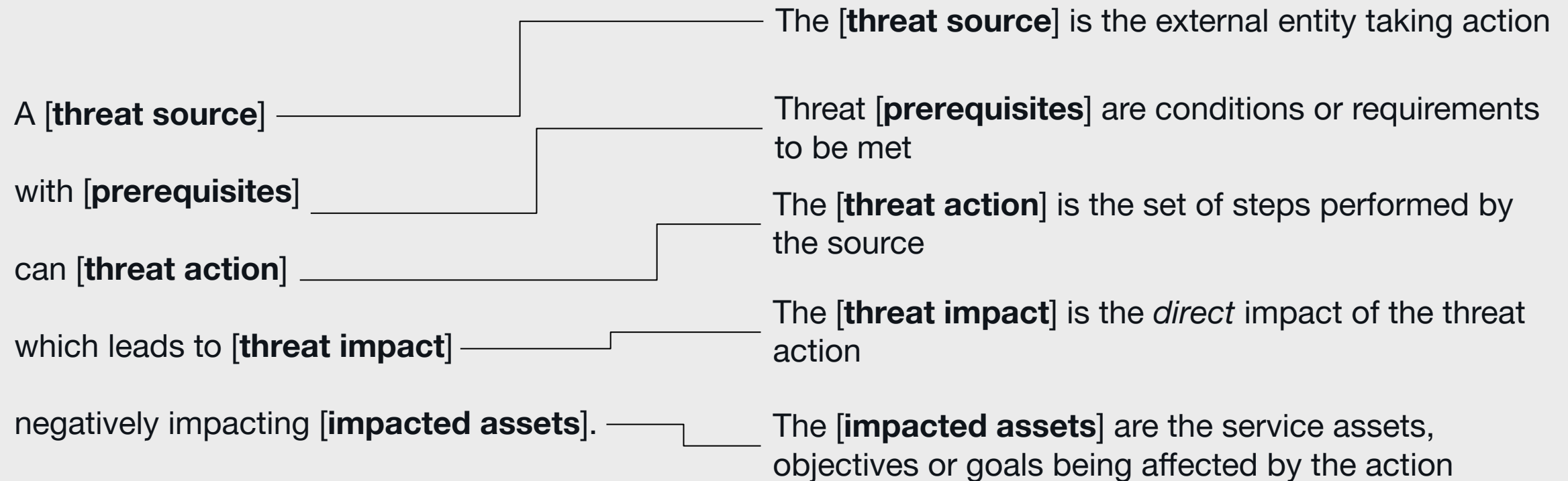
STRIDE-per-element

We will use the STRIDE mnemonic to **help brainstorm and categorise threats**, which will then be applied on a “per-element” basis to identify threats to the service in a **methodical and repeatable manner**.

				
Spoofing	✓	✓		
Tampering		✓	✓	✓
Repudiation	✓	✓	✓	
Information Disclosure		✓	✓	✓
Denial of Service		✓	✓	✓
Escalation of Privilege		✓		

AWS Threat Grammar

We will align our threat statements to **AWS Threat Grammar**, which helps to ensure consistent and concise threat statements are produced.



Let's identify some threats

Now using **STRIDE-per-element** and **AWS Threat Grammar**, let's identify some threats.

Spoofing an end user

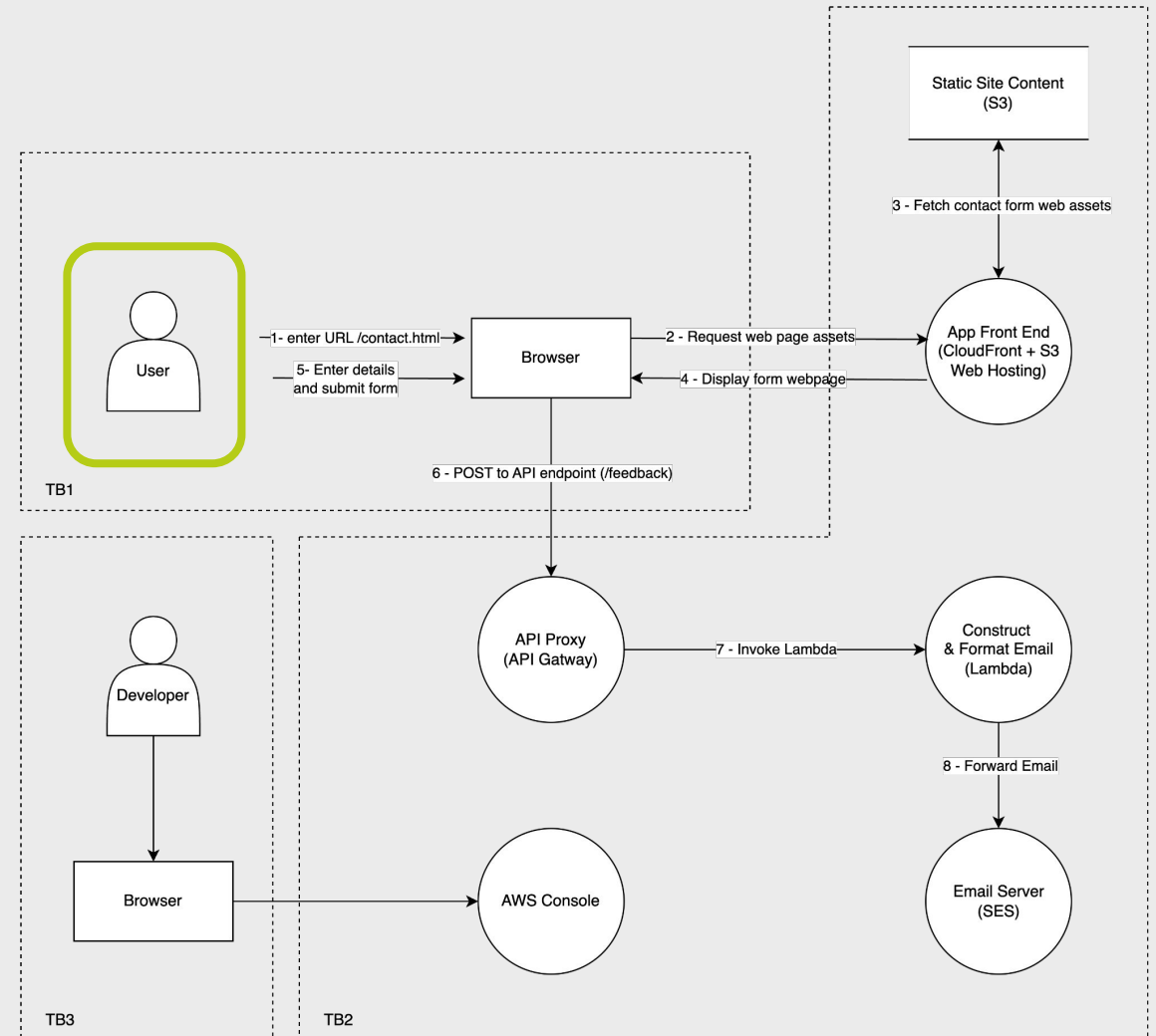
A **[threat source]**

with **[prerequisites]**

can **[threat action]**

which leads to **[threat impact]**

negatively impacting **[impacted assets]**



Let's identify some threats

Now using **STRIDE-per-element** and **AWS Threat Grammar**, let's identify some threats.

Tampering static site content in S3

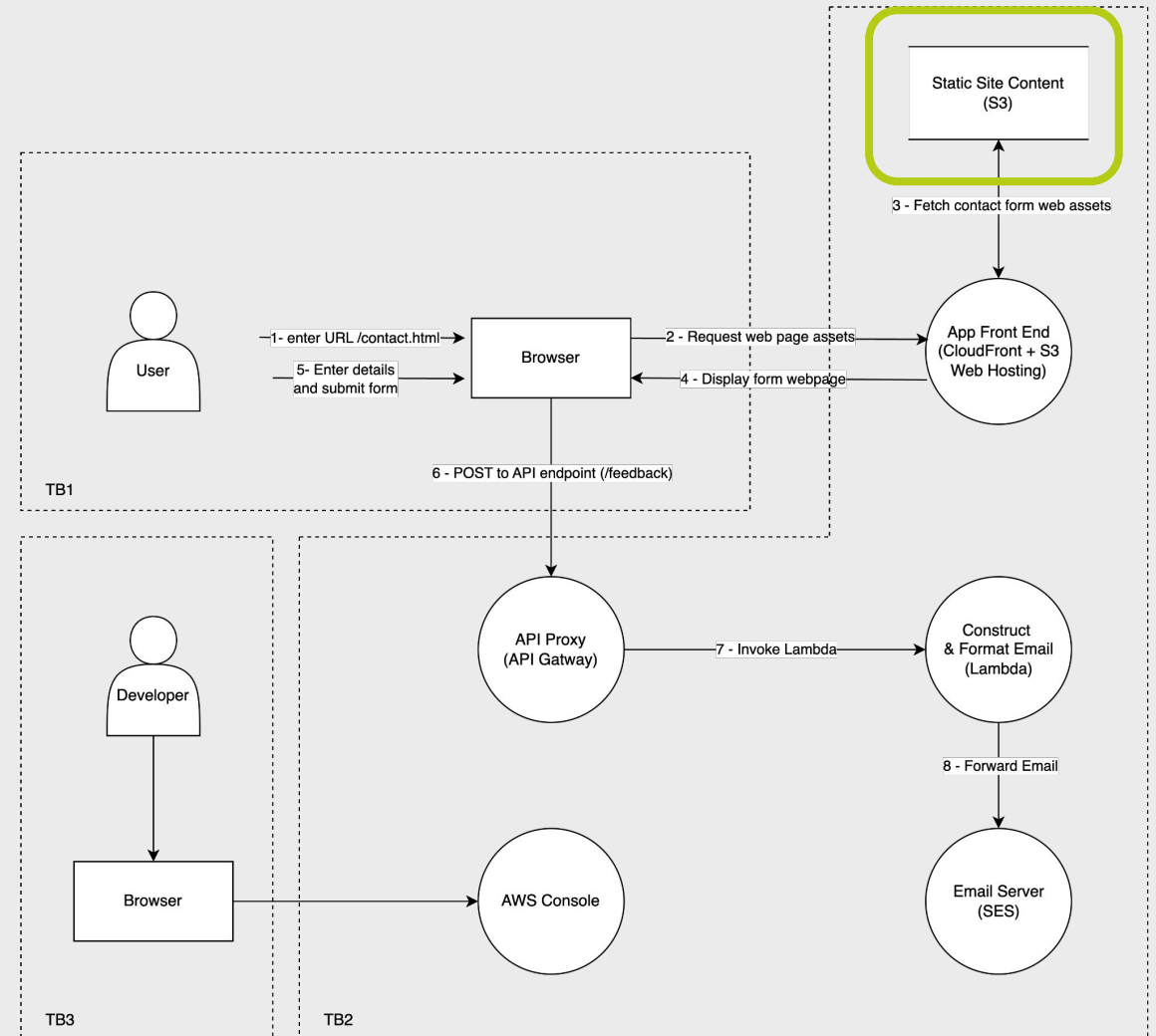
A [threat source]

with [prerequisites]

can [threat action]

which leads to [threat impact]

negatively impacting [impacted assets]

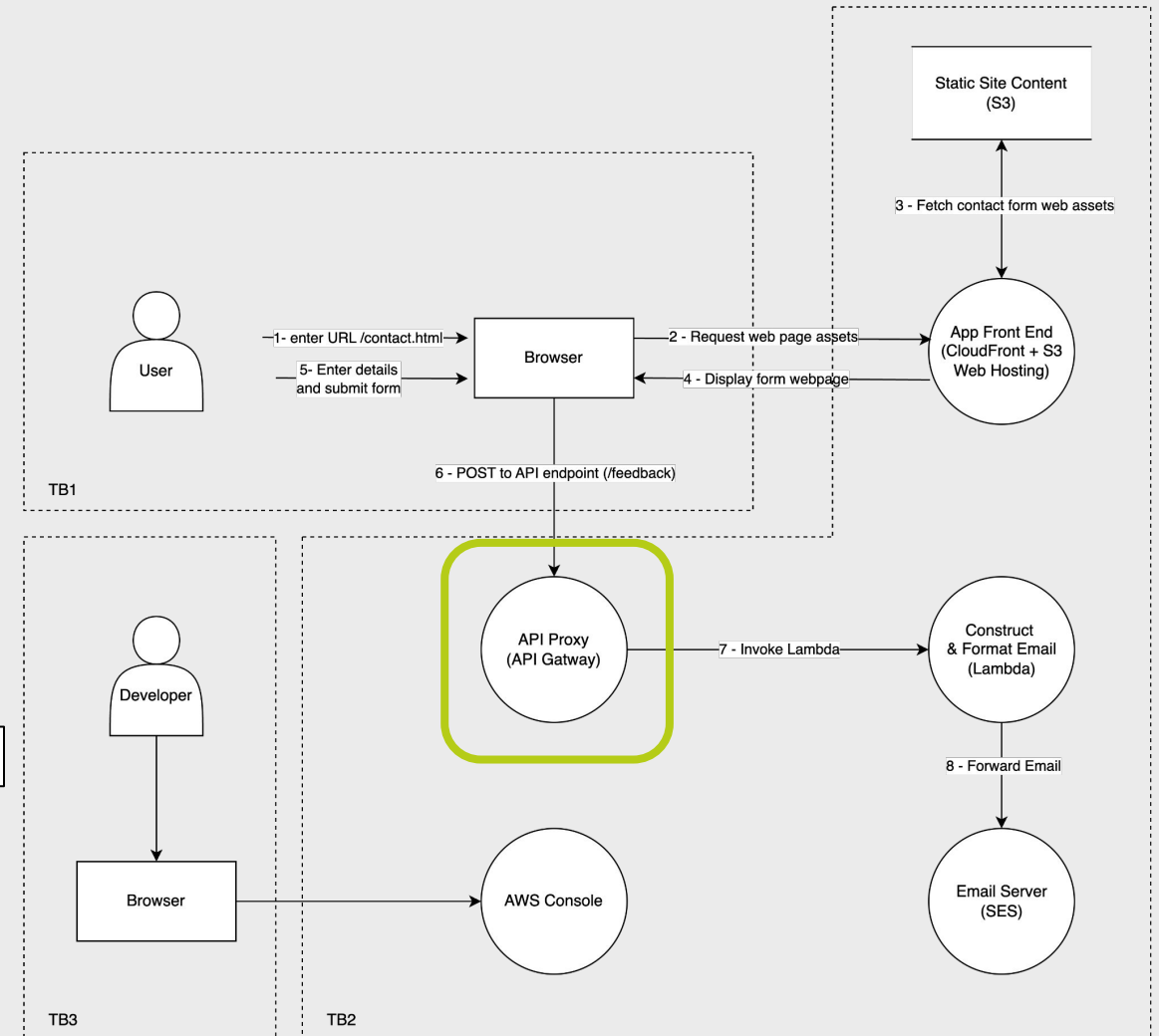


Let's identify some threats

Now using **STRIDE-per-element** and **AWS Threat Grammar**, let's identify some threats.

Denial of service against the API endpoint

A [threat source] with [prerequisites] can [threat action] which leads to [threat impact] negatively impacting the [impacted assets]



Determine threat priority

We will now prioritise the threats using factors that affect impact and likelihood of the threat occurring.

A reminder of **non-exhaustive** criteria that can be used to prioritise threats:

- Are the “crown jewels” impacted by the threat?
- Which security objectives are (CIA) impacted?
- Does the threat require a large number of prerequisites, and how difficult are they to obtain for an attacker?
- How complex is the required action (e.g., does it require the exploit of a zero-day vulnerability, can the process be automated)?

Question: Do you agree or disagree with this order?

Threat	Priority	Justification
Spoofing an end user	High	• Affects the integrity of the “crown jewel” asset of the given scope (i.e., user feedback)
Denial of service against API endpoint	High	• False feedback (spoofing) is more impactful than no feedback at all (above) • Minimal prerequisites • Common threat actor technique
Tampering static site content in S3	Medium	• Prerequisites much more difficult to obtain • Threat intel assesses that insider threat likelihood is minimal

Document threat mitigations

Now that we have identified some threats and determined their priority, let's propose some mitigations.

Threat	Priority	Proposed mitigations
Spoofing an end user	High	• Implement authentication as a requirement before feedback is submitted
Denial of service against API endpoint	High	• Enable AWS Shield • Implement throttling on the API Gateway • Configure AWS WAF to block signed traffic before it reaches underlying infrastructure
Tampering static site content in S3	Medium	• Implement logging and monitoring of S3 access • Enable object versioning, so old files can be recovered in the event that tampering occurs

Question: Are the mitigations written with enough detail? Can you think of any other mitigations?

Generate outputs and share with stakeholders

In the final phase, we will **compare our outputs to the definition of done** for this threat modelling exercise.

Typically this will be done via **peer review** within the Cyber Architecture team.

Definition of done

- Have all threats been aligned appropriately to AWS Threat Grammar, with potential mitigations assigned to each threat?
- Have actionable mitigations been applied to each threat?
- Have the outputs been shared with service owner and/or SRO?
- Has the next review or iteration of threat model been scheduled?

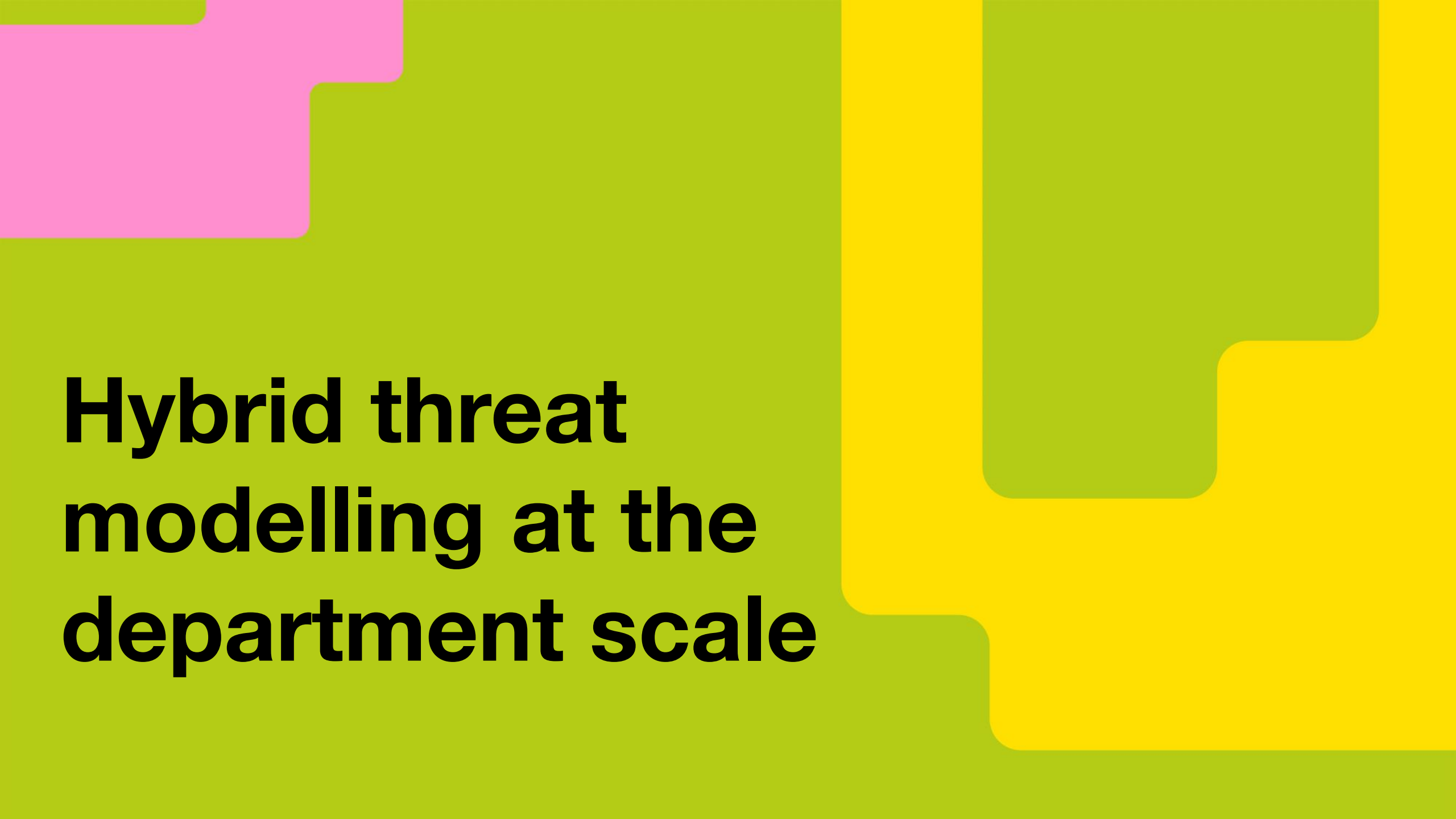


Cabinet Office
Digital

Threat Modelling Summary

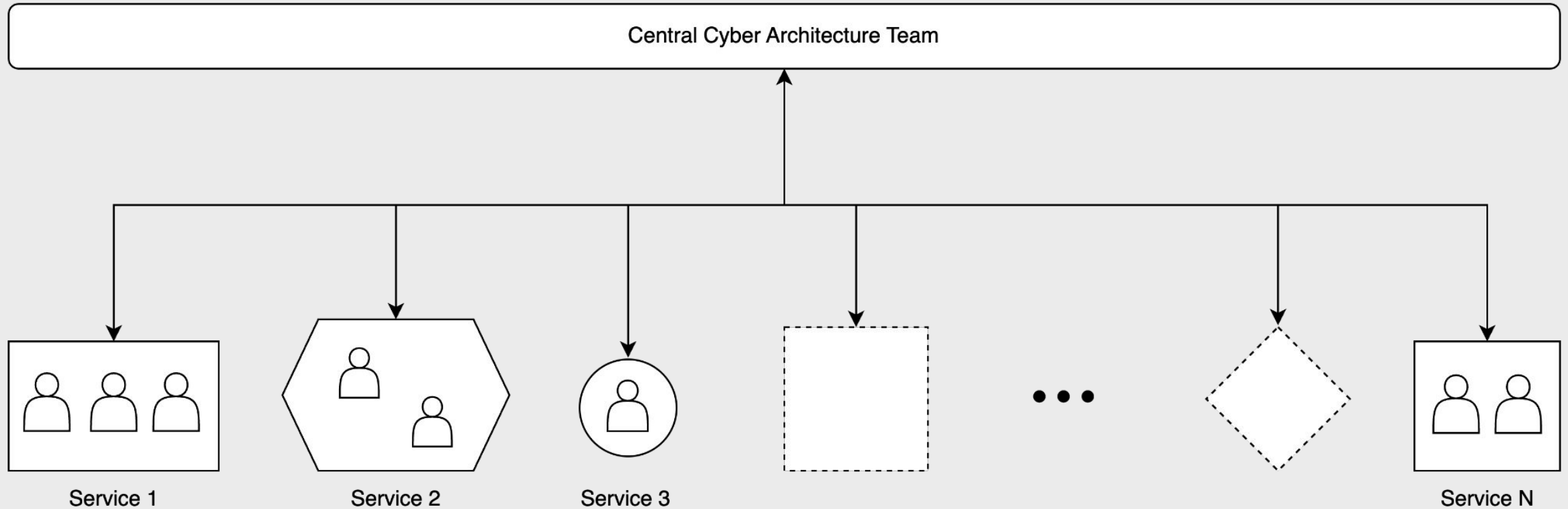
CO Cyber Architecture

Overview	2
Service Context	2
Motivation	2
Workshop	2
Users & Threat Actors	3
Assets and Components	3
Threats	4
Mitigations	7



Hybrid threat modelling at the department scale

What scales do we need to consider?



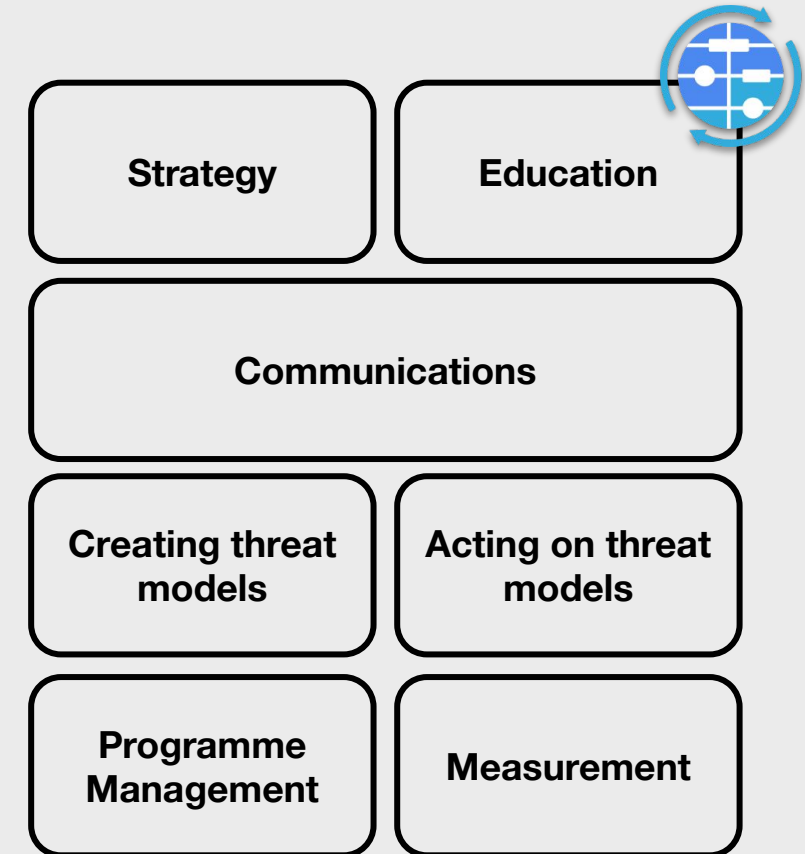
Threat Modelling Manifesto Capabilities

What are threat modelling capabilities?

- A catalogue of additional activities that constitute a successful threat modelling programme **at scale of an organisation or department**
- Capabilities define **what a department does** to enable process governance and consistent application of a department's chosen methodology
- Capabilities **do not** define how, why or where they should be implemented

How should capabilities be used?

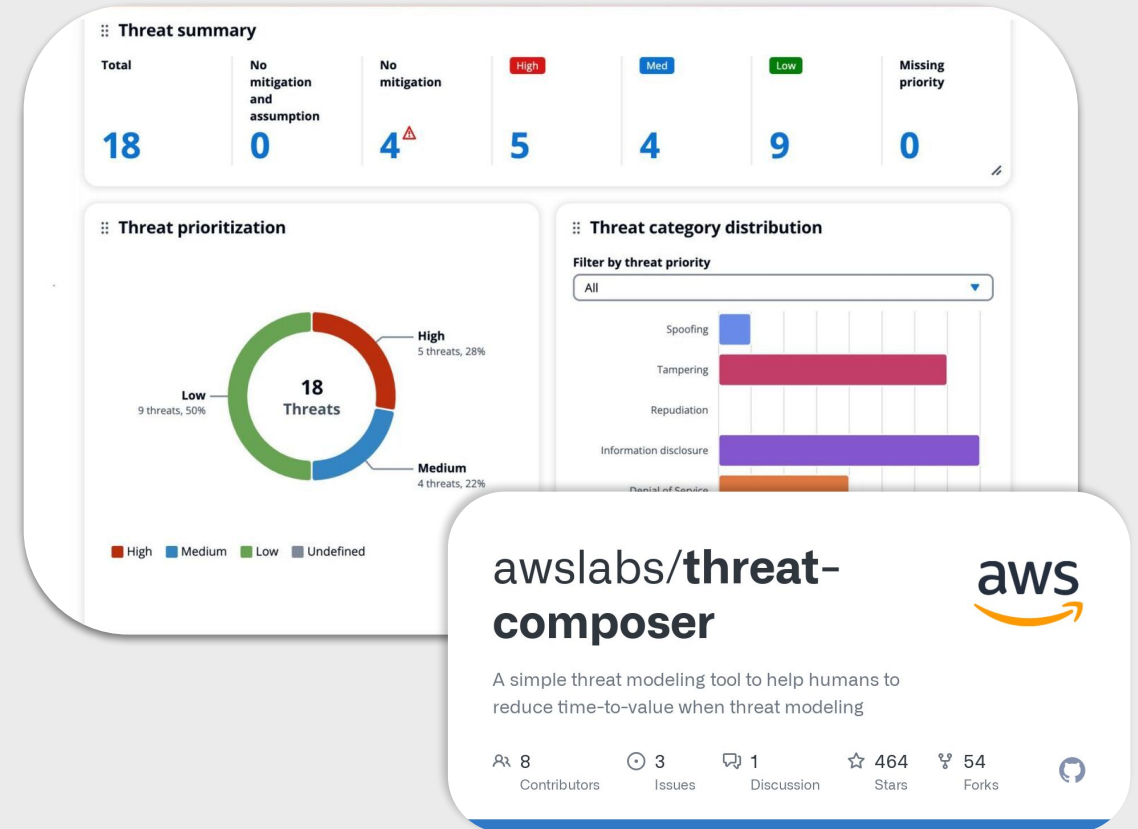
- The capabilities can be used to assess the maturity of an organisation's threat modelling programme, and to create a roadmap for continued improvement



Key capabilities we are prioritising

We have assessed our own methodology against the manifesto capabilities, and are looking to further mature our threat modelling service by:

- creating easy to access **threat models examples** for teams to learn from when creating their own to enable format consistency;
- creating a **catalogue of product-specific threats and mitigations libraries**, for reuse across services that share similar architectures and tech stacks;
- deploying our own instance of an **open source tool** (AWS Threat Composer) to help facilitate the end-to-end threat modelling process;



How to find out more



Web:

security.gov.uk/policy-and-guidance/secure-by-design/

Email:

secure-by-design@digital.cabinet-office.gov.uk

Slack:

[#xgov-sec-archs](#)

Blog:

cddo.blog.gov.uk/category/cyber-security/

Newsletter:

[Sign up](#)